Éléments pour le DPO — registre des traitements et analyse d'impact

Proposition à adapter par le délégué à la protection des données de l'établissement. Ce document ne constitue pas un avis juridique ; les rubriques marquées « à valider » relèvent de la décision du responsable de traitement.

1. Fiche du registre des traitements (proposition)

Rubrique	Contenu proposé
Nom du traitement	Suivi des mesures d'isolement et de contention en psychiatrie
Responsable de traitement	L'établissement, représenté par son directeur
Finalités	1. Suivre la durée des mesures d'isolement et de contention et leur cumul ; 2. Anticiper et tracer l'information et la saisine du juge des libertés et de la détention ; 3. Tracer l'information des tiers et les professionnels chargés de la surveillance ; 4. Tenir le registre prévu à l'article L. 3222-5-1 du code de la santé publique ; 5. Produire le rapport annuel et des statistiques anonymisées
Base légale (à valider)	Article 6.1.c du RGPD (obligation légale : registre et contrôle du juge, art. L. 3222-5-1 CSP) et 6.1.e (mission d'intérêt public) ; données de santé : article 9.2.h (prise en charge sanitaire) et 9.2.i (intérêt public dans le domaine de la santé publique)
Personnes concernées	Patients hospitalisés en psychiatrie faisant l'objet d'une mesure ; tiers informés (qualité seulement) ; professionnels (utilisateurs, psychiatres décisionnaires, soignants chargés de la surveillance)
Données des patients	Identité (nom, prénom, IPP, date de naissance), service, mode d'hospitalisation et son historique, mesure de protection juridique (oui ou type), mesures (type, lieu, dates et heures, psychiatre), information des tiers (qualité du tiers, résultat), communications avec le JLD
Données des professionnels	Nom, identifiant, rôles, services affectés ; horodatage et auteur de chaque saisie
Destinataires	Agents habilités des unités concernées, selon leur rôle et leurs services ; registre anonymisé : instances de contrôle prévues par la loi ; JLD : décompte joint aux communications
Transferts hors UE	Aucun. Les données ne quittent pas l'infrastructure de l'établissement. Si l'application est servie par GitHub Pages, seul le code est fourni par ce service, sans aucune donnée
Sous-traitants	Aucun pour les données (pas d'hébergeur externe)
Durée de conservation (à valider)	À fixer par l'établissement, en cohérence avec les règles applicables au registre et au dossier médical. L'outil conserve tout l'historique ; l'archivage d'une année close se fait en archivant une copie du dossier

Rubrique	Contenu proposé
Mesures de sécurité	Chiffrement AES-256 côté poste, comptes nominatifs et rôles, services affectés par compte, verrouillage après inactivité, journal inaltérable et chaîné, droits NTFS sur le dossier, sauvegardes, absence de flux sortant (voir la fiche technique)
Droits des personnes	Accès et rectification : consultation de la fiche patient et du détail des mesures, corrections tracées. Opposition et effacement : limités par l'obligation légale de tenue du registre (à valider)

2. Analyse d'impact (AIPD)

La liste de la CNIL des traitements pour lesquels une analyse d'impact est requise comprend les « traitements de données de santé mis en œuvre par les établissements de santé [...] pour la prise en charge des personnes » (CNIL). Le traitement porte en outre sur des personnes vulnérables, souvent hospitalisées sans leur consentement. **Une analyse d'impact paraît donc requise.** Elle peut être conduite avec l'outil PIA de la CNIL ; les éléments ci-dessous en préparent la partie « risques ».

Risques et mesures

Événement redouté	Sources possibles	Mesures existantes	Gravité / vraisemblance (à évaluer)
Accès illégitime aux données	Copie du dossier, poste laissé ouvert, agent hors de son périmètre	Chiffrement ; mots de passe ou clés matérielles ; verrouillage automatique ; services affectés par compte ; droits NTFS ; journal nominatif	
Modification non désirée	Erreur de saisie, saisies concurrentes, manipulation	Journal en ajout seul ; corrections et annulations tracées avec motif ; détection des conflits ; chiffrement authentifié (un fichier modifié est rejeté)	
Disparition des données	Suppression de fichiers, panne, perte des moyens de déverrouillage	Sauvegardes du partage ; détection des saisies manquantes ; deux clés d'administration et code de secours au coffre ; procédure dégradée papier	

Points d'attention pour l'analyse

- Le contrôle des rôles est réalisé par l'application sur le poste, sans serveur : un utilisateur disposant d'un compte valide et de compétences techniques pourrait le contourner, sans pouvoir effacer la trace de ses saisies.
- La perte simultanée de tous les moyens de déverrouillage rend les données irrécupérables : c'est la contrepartie d'un chiffrement effectif.
- Le registre anonymisé et les exports statistiques ne contiennent ni nom ni IPP ; l'export détaillé utilise des pseudonymes (P001, P002...). Le nom du psychiatre figure au registre ; sa communication à des tiers peut appeler une occultation selon la doctrine de la CADA.
- Les impressions (décompte JLD, registre) sont des documents à protéger comme le dossier patient.

3. Mode formation

Le jeu de formation ne contient que des données fictives générées par l'application (noms marqués « fictif »). Il est chiffré séparément et rangé dans le même dossier que les données réelles. La consigne de ne jamais y saisir de donnée réelle figure dans le bandeau affiché en permanence et dans les procédures ; le formateur peut régénérer le jeu à tout moment, ce qui efface son contenu.

4. Information des personnes

Les patients sont informés par les moyens habituels de l'établissement (livret d'accueil, affichage, politique de confidentialité), en mentionnant ce traitement, ses finalités et les modalités d'exercice des droits.

Sources : CNIL, liste des types d'opérations de traitement pour lesquelles une AIPD est requise ; article L. 3222-5-1 du code de la santé publique ; ANS, champ d'application de l'hébergement de données de santé ; MACSF, registre et occultation du nom du psychiatre.